

Insecure Design Assignment

Threat Modeling

Part 1: Threat Modeling – Decomposing Your application

To understand the design, insecure or otherwise, we must understand the application. Threat Modeling is a technique that allows us to explore the application to understand the design and components so that we can analyze and perform the design analysis based on risk. For Part One of Assignment, we will be doing Application decomposition as described in the OWASP link.

https://owasp.org/www-community/Threat_Modeling_Process

The following document will provide a template and form the Rubric for the assessment of the assignment.

Your application will be based on the Juice Shop application. From an architecture perspective it will have the same structure unless there are deviations specified in your handout

First step is to describe Identify you application

Note: Use your own words and do not cut and paste from Juice Shop collateral

1) Threat Model information

<As described in Sample in the link>

2) External Dependencies

<In this example you will have to envision a deployment option for a production system and may have to include where this could be hosted. Focus on technology and use fictional physical locations that might be available to you as a student at NSCC. It should be in tabular form as in the example.>

3) Entry Points & Exit Points

<It should be in tabular form, as in the example. They can probably be in the same table or in separate tables >

4) Assets

<Once again in tabular form, as per the example. This section will have more weight in the rubric – as it's a critical component >

5) Trust Level (identities)

<It should be in tabular form, as in the example.>

6) Data Flow Diagram

<This is also an important part of the assignment. It is not necessary to use any particular tool however try to ensure you model the most important data assets in the system. I recommend draw.io could be used <https://www.drawio.com/blog/data-flow-diagrams> as an easy to use tool>

Part 2: Threat Modeling – Determine and Rank Threats

Part 2 of the assignment is to complete determine and rank the threats based on the OWASP guidance.

https://owasp.org/www-community/Threat_Modeling_Process#step-2-determine-and-rank-threats

7) STRIDE analysis

<Complete the STRIDE analysis based on the table in the online documentation, there will be similarities but your teams analysis should be different >

8) OWASP Risk Rating Model analysis.

<Complete the OWASP Risk Rating Model analysis based on the table in the online documentation, there will be similarities but your teams analysis should be different >

Part 3: Threat Modeling – Countermeasures and Mitigation

Part 3 of the assignment is to complete countermeasure and migration strategies based on the OWASP guidance.

https://owasp.org/www-community/Threat_Modeling_Process

9) Countermeasures and Mitigation

< Based on the top-ranked threats (at least 5)

- Complete a mitigation plan as described in the OWASP guide
- Include any CVE's that are known from Juice Shop
- There may be similarities but your teams analysis should be different
- In your own words Describe any mitigations – Use the Design Principals, Design and coding (and cheat sheets) to protect against threats>

Part 4: Conclusion and SAST Scan

- In your own words Indicate how these might align with the OWASP top 10
- Scan the code using SonarCube, and include a screenshot of the results in your report.

We will include a peer review component.

Upload the file to Brightspace Assignment "Assignment – insecure Design – Threat Model."